Module 5 Tabletop Kit: RSSO Incident Response

How the exercise works

Your team is the RSSO's response team. Director Eva has delegated the response to you: your incident commander may order any containment step, but a public statement, a payment, or reopening services needs the head's approval. The facilitators form the **white cell**. They give you new information (**injects**) as the fictional clock moves, and they play everyone outside your team: Director Eva, staff, vendors, the media and the NPC. Everything in this kit is fictional.

Round	Fictional time	Minutes	Decisions to record in your log
1. Detect	Friday, 4:45 PM to 9:00 PM	25	The incident and its severity; who is called; the first containment step; whether personal data is involved; when the 72-hour clock starts
2. Contain and eradicate	Saturday	30	What to isolate; how evidence is kept; the eradication plan; a holding statement; whether the clock has already started
3. Notify and recover	Sunday to Monday	25	The notices to the NPC and the people affected; any request to the NPC; reports to DICT and law enforcement; the ransom stance; the restore order; lessons learned

Rules

1. Draw roles by lot. Anyone who led an earlier activity takes a different role. Teams of five combine the scribe and the communications lead.
2. Log every decision with its fictional time, who decided, and why.
3. Ask the white cell anything you would ask in real life: it answers in character. Online, ask in your breakout room's chat.
4. Stay in role. The incident commander has the final word; the scribe records any disagreement.
5. Name nothing real: no real offices, people or systems.

What you submit

Deliverable	When	How
Immediate response plan (one page)	At the end of Round 1	Hand it to the white cell, or post it in your room's chat
Incident log	Kept from the first minute	Part of your final file
Final incident report	By 11:15 AM	One file per team through the submission link. If connectivity fails, the grace period runs until 5:00 PM the same day

The RSSO at a glance

The Regional Social Services Office (RSSO) of fictional Region Q, a few weeks after the October controls audit from Module 4. Director Eva approved the audit's fixes, but IT had not yet started them.

Item	Detail
Office	About 60 staff; open Monday to Friday, 8:00 AM to 5:00 PM
Main system	The RSSO Assistance Portal, at assist.rsso-q.example, running on the office server in the server room
Data	About 48,000 applicants: name, address, birthdate, mobile number, government ID number and e-wallet number; for medical assistance, health information and a medical certificate; uploaded ID images
Other systems	A file server with a shared drive for every unit; office email; payouts through Vendor C's business portal
Payouts	Released every Monday from 10:00 AM
Backups	Each night, a copy goes to a USB drive attached to the server. Once a month, Ana copies it to a second drive kept in Director Eva's office safe

Item	Detail
Plan	A 2021 draft incident response plan exists but was never approved. No Data Breach Response Team has been named
People	Director Eva, head of office; Carla, DPO and legal officer; Ana, IT officer; Ben, records clerk; Dan, cashier; Sol, social worker; Rosa and Leo, supervisors
Vendors	Vendor A, the portal developer (support contract ended 30 June; renewal in procurement); Vendor B, the SMS service (agreement expired 31 July; service continues); Vendor C, the e-wallet provider (agreement current, with breach notice to the RSSO within 24 hours)
Known gaps	Your Module 4 findings register: they were all still open on the day this exercise starts

Contacts the white cell can play

Who	How to reach them in the exercise
Director Eva, head of office	By phone, any time
Ana, Ben, Dan, Sol, Rosa, Leo	By phone; Ben and Dan are at home after 5:00 PM
Vendors A, B and C	Office hours only, except Vendor C's 24-hour fraud line
The NPC	Through the DBNMS; the white cell plays the Commission
DICT's National CERT	Through the channel in DICT Department Circular 005
The NBI or the PNP Anti-Cybercrime Group	By phone or in person
The media	They call you

Role cards

Cut these out face-to-face, or paste your role's card into your room's chat online. Every member holds one role and speaks for it.

Role	You own	Ask first	You produce
Incident commander	Declaring the incident and its severity; the final word on each decision; what goes to Director Eva for approval	What do we know, what do we not know, and what must be decided now?	Decisions with reasons; the request to the head for any statement, payment or reopening
Technical lead	Which systems are affected; isolation; evidence; eradication; restoring service	What is affected, how did they get in, and is the attacker still inside?	Containment and eradication steps; the restore order
DPO or privacy lead	Whether personal data is involved; the 3S decision; the clock; notices to the NPC and the people affected	Which personal data, how many people, and since when do we reasonably believe it was taken?	The clock start with a reason; the NPC notification; the notice to affected people; any request to the NPC
Communications lead	Staff updates; the holding statement; media calls; messages to applicants	Who needs to hear what, from whom, and when is the next update?	The holding statement; internal notices; the public message
Scribe	The incident log; the timeline; the final report draft	What just happened, who decided it, and why?	The log, kept from the first minute; the final report
Legal or head-of-office liaison	Reports to DICT and law enforcement; links to the central office; legal risk	What do the law and our plan require us to report, and to whom?	Reports to the National CERT and law enforcement; advice on the ransom and on any statement

Teams of five: the scribe also acts as communications lead.

The starting situation

Friday, 4:45 PM. Most staff are packing up for the weekend. Ben calls Ana from the records section: the files on the shared drive have new names and will not open, and a new file called RESTORE_YOUR_FILES sits in every folder. The note says that the office's files are locked, that its data has been copied, and that the data will be published unless a payment is made within 72 hours. Two other units report the same. The portal still loads for citizens, but Ana cannot open its admin page.

The white cell will bring more information as the clock moves. Ask it anything you would ask in real life.

Your first ten minutes

1. Name the scribe, and start the log at Friday 4:45 PM.
2. Decide: is this an incident? How severe is it, and why?
3. Decide whom to call, in what order, and who calls them.
4. Choose the first containment step, and what must be preserved before anything is changed.
5. Decide whether personal data may be involved, and record your clock-start decision with its reason, even if it is "not yet".

Incident log

The scribe keeps this from the first minute. One line per event, decision or action. Add rows as needed.

#	Fictional time	What happened or was decided	Who	Why, or the source of the information
1	Fri 4:45 PM			
2				
3				
4				
5				
6				
7				
8				

#	Fictional time	What happened or was decided	Who	Why, or the source of the information
9				
10				
11				
12				
13				
14				
15				
16				
17				
18				
19				
20				

Immediate response plan

One page, due at the end of Round 1. Write what your team has decided, not what it might do.

#	Item	Your team's answer
1	Incident declared at (fictional time), by (role)	
2	Severity (Low, High or Critical), and why	
3	What we know	
4	What we do not know yet, and who is finding out	
5	Personal data involved? Yes, no or unknown, and which kinds	
6	Clock start: our decision and the reason	
7	First containment steps: what, who, by when	
8	Evidence we are preserving: what, who	

#	Item	Your team's answer
9	Who we have told inside the office	
10	Who we will tell outside the office, and when	
11	What needs Director Eva's approval	
12	Our next check-in time	

Final incident report

Due at 11:15 AM. The structure follows what NPC Circular 16-03 asks an office to document (Section 9) and to tell the NPC and the people affected (Sections 17 and 18).

Part 1. Summary

In three to five sentences: what happened, when it was discovered, what was affected, and where things stand now.

Part 2. Timeline

The key moments from your log: discovery, declaration, each containment step, each notification, the return to service.

Fictional time	Event or decision

Part 3. Systems and data affected

Item	Answer
Systems affected	
Kinds of personal data involved	
Sensitive personal information involved	
Approximate number of people, or records	
Breach type: availability, integrity, confidentiality (any that apply)	

Part 4. Actions taken

Phase	What was done, by whom, when
Containment	
Evidence preserved	
Eradication	
Recovery, and the restore order	

Part 5. Notification decisions

Report to	Decision and time	Reason
The NPC, through the DBNMS		
The people affected		
Any request to the NPC (exemption, postponement, alternative means)		
The full breach report to the NPC (within 5 days)		
DICT's National CERT		
The NBI or the PNP Anti-Cybercrime Group		
Others (central office, vendors, partners)		

Part 6. Draft notification to the NPC

Field	Your draft
How the breach happened, and the weakness that allowed it	
Chronology of events	
Approximate number of people or records	
Kind of breach, and its likely consequences	
Sensitive personal information involved	
Other information that could enable identity fraud	
Measures taken or planned: to address the breach, recover the data, and reduce harm	
How the people affected are being told, or the reason for any delay	
Measures to prevent a repeat	
DPO's name and contact details (fictional)	

Part 7. Draft notice to the people affected

Plain words, no more than 150 words, sent to each person individually by secure means. It must say: what happened; which of their data may be involved; what the office has done to address it and to reduce harm; whom to contact; and what help is offered. Add one line on what the person can do now, such as watching for fake RSSO messages.

> Write your notice here.

Part 8. Preliminary root cause

How did the attacker get in, and which controls failed? Link each cause to a finding from your Module 4 register where you can.

Part 9. Lessons learned

#	Action	Owner (role or RSSO cast)	By when
1			

#	Action	Owner (role or RSSO cast)	By when
2			
3			
4			
5			

Part 10. Team and roles

Member	Role	Main contribution

Quick reference

Question	Answer	Source
Must we notify?	When all three are true: **Sensitive** (sensitive personal information, or data that could enable identity fraud), **Stolen** (reason to believe someone not authorized acquired it), **Serious** (a real risk of serious harm). Unsure: weigh the likelihood of harm first; also 100 or more people, public safety, confidential information, vulnerable groups	NPC Circular 16-03, Secs 11 and 13
When does the clock start?	When the office knows or reasonably believes that a breach needing notification has happened. Certainty is not required: smoke, not ashes	Sec 17
How long?	**72-5:** the NPC and each affected person within 72 hours; the full report within 5 days from discovery. No delay when 100 or more people are affected	Secs 17 and 18; Advisory 2026-02

Question	Answer	Source
What do we tell the NPC?	How it happened and the weakness; a timeline; how many people; the kind of breach and its likely consequences; the data involved; what was done and is planned; how people are being told; the DPO's contact	Sec 17
What do we tell each person?	What happened; which of their data; what was done to address it and reduce harm; whom to contact; what help is offered. Individually, by secure means	Sec 18
Can we wait for the NPC to answer a request?	No: approval must be express and in writing. Silence is not approval	Advisory 2026-02
Where do we file?	The NPC's DBNMS; the full report to admindbnms@privacy.gov.ph	NPC; Advisory 2026-02
May we keep it quiet?	No. Concealing a breach of sensitive personal information is a crime	RA 10173, Sec 30
Who else?	DICT, through the channel in its Department Circular 005; the NBI or the PNP Anti-Cybercrime Group when a crime may have been committed	DICT DC 005 (2024); RA 10175, Sec 10
First technical moves?	Isolate first, power off last; preserve before you wipe; restore only from backups verified clean	CISA
Should we pay?	The FBI does not support paying: it does not guarantee the data back. Paying does not end the duty to notify	FBI

How it is scored (100 points, scaled to 40%)

Criterion	Points	Full marks means
Legal protocols and DPA notification	40	A correct breach decision; a defensible clock start; complete content for the NPC and for the people affected; requests handled properly; DBNMS filing and documentation; other reports identified
Logic of containment	30	A sensible order and scope; evidence preserved; eradication and recovery justified
Final incident report	30	Accurate and complete, with a clear timeline, a preliminary root cause, and lessons learned with owners
Participation check	Gate	Every member held a role and contributed; exceptions are flagged to ILCDB, not scored

Every member receives the team score. The white cell scores the rounds from your log and its own notes; the report is scored after the session.